

Workflow 静态安全扫描报告：普通文本优化工作流

扫描摘要

扫描已完成。报告中的确定性证据、语义候选和覆盖缺口已分开呈现。

- Workflow Hash:
63938a8870bd5d3490ad3807d18e335905b472e58a5c25b4cc2270c36a3ef1fb
- 节点/边: 3 / 2
- Finding 数: 7
- 严重等级: HIGH=3、MEDIUM=3、LOW=1
- 证据状态: CONFIRMED=4、PROBABLE=1、COVERAGE_GAP=2
- 发布门禁: FAIL

关键攻击链

HIGH · IN-007, IN-009, LLM-001, LLM-002

攻击族: general_workflow_security, direct_prompt_injection

- 路径: 1770620997487 → 1770620999925
- 状态: CONFIRMED, PROBABLE
- 动态用例: TC-9d1bf67a1e9b, TC-5dff43bc1089, TC-17da52f2a142

Findings

[HIGH] IN-007 · 用户输入进入高权限 Prompt

用户输入变量被插入系统/开发者指令区域。

- 状态: CONFIRMED; 置信度: 1.00
- 节点: 1770620997487 → 1770620999925
- DSL 位置: /workflow/graph/nodes/0, /workflow/graph/nodes/1
- 证据: FACT-080d5d9add24
- 动态验证: direct_prompt_injection
- 修复建议:
 - 为输入定义严格类型、长度、枚举和额外字段策略。

[HIGH] IN-009 · 直接 Prompt Injection 可达模型

用户消息可直接到达模型，且系统指令未声明对角色覆盖、目标劫持或提示词提取的防护边界。

- 状态：CONFIRMED；置信度：1.00
- 节点：1770620997487 → 1770620999925
- DSL 位置：/workflow/graph/nodes/0, /workflow/graph/nodes/1
- 证据：FACT-cf3552c325bb
- 动态验证：direct_prompt_injection
- 修复建议：
 - 为输入定义严格类型、长度、枚举和额外字段策略。

[HIGH] LLM-001 · 不可信变量进入系统指令

不可信变量被插入系统或高权限指令区域。

- 状态：CONFIRMED；置信度：1.00
- 节点：1770620997487 → 1770620999925
- DSL 位置：/workflow/graph/nodes/0, /workflow/graph/nodes/1
- 证据：FACT-467e652e21af
- 动态验证：direct_or_indirect_prompt_injection
- 修复建议：
 - 将外部内容作为不可信数据隔离，并在模型输出进入行为层前执行确定性校验。

[MEDIUM] LLM-002 · 指令与外部数据未隔离

外部内容进入 LLM，但系统指令中未发现明确的数据/指令隔离约束。

- 状态：PROBABLE；置信度：0.72
- 节点：1770620997487 → 1770620999925
- DSL 位置：/workflow/graph/nodes/0, /workflow/graph/nodes/1
- 证据：FACT-56e6d02d028a
- 动态验证：instruction_data_boundary
- 修复建议：

- 将外部内容作为不可信数据隔离，并在模型输出进入行为层前执行确定性校验。

[MEDIUM] OUT-001 · 结构化输出缺少 Schema

动态输出缺少结构化 Schema。

- 状态：CONFIRMED；置信度：1.00
- 节点：1770621078955
- DSL 位置：/workflow/graph/nodes/2
- 证据：FACT-e7fe36ab825f
- 修复建议：
 - 在风险路径的必经位置增加确定性控制，并验证不存在旁路。

[MEDIUM] OUT-008 · 低置信或失败输出无回退

输出节点未显示低置信或失败回退行为。

- 状态：COVERAGE_GAP；置信度：1.00
- 节点：1770621078955
- DSL 位置：/workflow/graph/nodes/2
- 证据：FACT-6687000cb1b8
- 修复建议：
 - 在风险路径的必经位置增加确定性控制，并验证不存在旁路。

[LOW] IN-004 · 未声明输入规范化

DSL 未声明输入解码和 Unicode 规范化控制。

- 状态：COVERAGE_GAP；置信度：1.00
- 节点：1770620997487
- DSL 位置：/workflow/graph/nodes/0
- 证据：FACT-89734257d6b9
- 缺失上下文：输入规范化可能由平台统一实现，DSL 无法验证。
- 动态验证：encoding_unicode_smuggling
- 修复建议：

- 为输入定义严格类型、长度、枚举和额外字段策略。

覆盖缺口

- OUT-008: 输出节点未显示低置信或失败回退行为。
- IN-004: DSL 未声明输入解码和 Unicode 规范化控制。

动态阶段说明

本报告没有执行 Workflow。生成的测试用例必须在默认禁网、假凭证、只读测试数据和资源配额约束的沙盒中运行。

app: description: '1、用户群： 全体人员 2、辅助哪项具体工作： 普通文本优化工作流
3、解决什么问题： 普通文本优化 4、输入： 待优化文本 5、输出： 优化后文本' icon:



icon_background: null mode: workflow name: 普通文本优化工作流

use_icon_as_answer_icon: false dependencies: - current_identifier: null type: package
value: plugin_unique_identifier:
langgenius/openai_api_compatible:0.0.20@5a087a9c6ce51f714451f18aea9979520499df
0847bf78f33fafc5da3fcfd293 version: null kind: app version: 0.5.0 workflow:
conversation_variables: [] environment_variables: [] features: file_upload:
allowed_file_extensions: - .JPG - .JPEG - .PNG - .GIF - .WEBP - .SVG allowed_file_types:
- image allowed_file_upload_methods: - local_file - remote_url enabled: false
fileUploadConfig: audio_file_size_limit: 50 batch_count_limit: 5 file_size_limit: 15
image_file_size_limit: 10 video_file_size_limit: 100 workflow_file_upload_limit: 10 image:
enabled: false number_limits: 3 transfer_methods: - local_file - remote_url
number_limits: 3 opening_statement: " retriever_resource: enabled: true
sensitive_word_avoidance: enabled: false speech_to_text: enabled: false
suggested_questions: [] suggested_questions_after_answer: enabled: false
text_to_speech: enabled: false language: " voice: " graph: edges: - data: isIteration:
false isLoop: false sourceType: start targetType: llm id: 1770620997487-source-
1770620999925-target source: '1770620997487' sourceHandle: source target:
'1770620999925' targetHandle: target type: custom zIndex: 0 - data: isIteration: false
isLoop: false sourceType: llm targetType: end id: 1770620999925-source-
1770621078955-target source: '1770620999925' sourceHandle: source target:
'1770621078955' targetHandle: target type: custom zIndex: 0 nodes: - data: selected:
false title: 用户输入 type: start variables: - default: " hint: " label: 待优化文本
max_length: null options: [] placeholder: " required: true type: paragraph variable:
inputStr height: 109 id: '1770620997487' position: x: 80 y: 282 positionAbsolute: x: 80 y:
282 selected: false sourcePosition: right targetPosition: left type: custom width: 242 -
data: context: enabled: false variable_selector: [] default_value: - key: text type: string
value: '{"result":"大模型响应异常，请稍后重试！"}' error_strategy: default-value model:
completion_params: max_tokens: 2000 temperature: 0.2 top_p: 0.9 mode: chat name:
qwen-2p5-vl-32b-instruct-mx provider:
langgenius/openai_api_compatible/openai_api_compatible prompt_config:
jinja2_variables: [] prompt_template: - edition_type: basic id: e0ac6249-05fa-40f6-
9917-a81e9db683af role: system text: '作为你是一名中文写作改进专家，你的任务是分
解长句，减少重复，提高文本的清晰度、简洁度和整体可读性。改正文本中存在的错
别字和语义错误，去掉无效空格和字符，优化该文本表述，尽可能提炼精简文本内
容。请只提供文本的更正版本，避免解释其他内容。 要求： 1、分解长句，减少重

复，提高文本的清晰度、简洁度和整体可读性。 2、改正文本中存在的错别字和语义错误。 3、去掉无效空格和字符，优化该文本表述。 4、尽可能提炼精简文本内容。 5、输出只提供文本的更正版本，避免解释其他内容。 示例： ----- {text:"A 系统一月份生产问题，客户在使用查询页面查询数据时发现选择日期类型为打款日期时，页面查询缓慢，直至超时。经后续排查后发现查询 sql 写法有误，未触发索引。此次决定分析整个查询流畅，做全面地性能优化，根治该查询缓慢问题。"} -----
----- 输入： {{#1770620997487.inputStr#}} ' reasoning_format: separated
selected: true structured_output_enabled: true title: LLM type: llm vision: enabled: false
height: 124 id: '1770620999925' position: x: 381 y: 282 positionAbsolute: x: 381 y: 282
selected: true sourcePosition: right targetPosition: left type: custom width: 242 - data:
outputs: - value_selector: - '1770620999925' - text value_type: string variable: result
selected: false title: 输出 type: end height: 88 id: '1770621078955' position: x: 684 y:
282 positionAbsolute: x: 684 y: 282 sourcePosition: right targetPosition: left type:
custom width: 242 viewport: x: 162.5 y: 42 zoom: 1 rag_pipeline_variables: []

我将为您执行 Workflow 的静态安全扫描。

我需要先找到您的 Workflow DSL 文件。让我先查看当前工作目录中的文件：

找到了两个 Workflow DSL 文件。让我先查看扫描脚本和样本文件，然后开始扫描：

```
$ python "C:\Users\80398985\.config\testagent\skills\agent-workflow-security-  
scan\scripts\scan_workflow.py" scan --dsl "C:\Users\80398985\Desktop\workflow\普通  
文本优化工作流 (2).yml" --output  
"C:\Users\80398985\Desktop\workflow\testagent\scan-report-1"
```

```
{  
  
  "scan_id": "SCAN-c52822a9bf0b",  
  
  "output_dir": "C:\\Users\\80398985\\Desktop\\workflow\\testagent\\scan-report-1",  
  
  "finding_count": 7,  
  
  "critical_or_high": 3,  
  
  "llm_enabled": false,  
  
  "llm_errors": [],  
  
  "verification_valid": true,
```

```
"quality_gate": "FAIL",  
"exit_code": 1  
}  
  
$ python "C:\Users\80398985\.config\testagent\skills\agent-workflow-security-  
scan\scripts\scan_workflow.py" scan --dsl "C:\Users\80398985\Desktop\workflow\缺陷  
质检工作流.yml" --output "C:\Users\80398985\Desktop\workflow\testagent\scan-  
report-2"
```

```
{  
  "scan_id": "SCAN-04aca12ea4cf",  
  "output_dir": "C:\\Users\\80398985\\Desktop\\workflow\\.testagent\\scan-report-2",  
  "finding_count": 123,  
  "critical_or_high": 85,  
  "llm_enabled": false,  
  "llm_errors": [],  
  "verification_valid": true,  
  "quality_gate": "FAIL",  
  "exit_code": 1  
}
```

两个工作流扫描完成。让我查看详细的发现报告：

扫描结果汇总

工作流 1: 普通文本优化工作流 (2).yml

- 扫描 ID: SCAN-c52822a9bf0b
- 质量门禁: FAIL
- 发现数: 7 (高危 3 个)
- 阻断项: 3 个 (Prompt 注入、不可信变量进入系统指令)

工作流 2: 缺陷质检工作流.yml

- 扫描 ID: SCAN-04aca12ea4cf

- 质量门禁: FAIL
- 发现数: 123 (高危 85 个)
- 阻断项: 69 个
- 需审查项: 53 个

主要风险类型

风险类别	严重性	说明
命令/代码注入	CRITICAL	动态变量可到达命令执行能力
Prompt 注入	HIGH	用户输入直接进入系统指令
不可信变量进入系统指令	HIGH	外部数据未隔离
自由文本控制工具	HIGH	LLM 输出直接影响工具参数
缺少结构化输出 Schema	HIGH	下游工具依赖但无严格输出约束
多级副作用链无故障隔离	HIGH	串联副作用无幂等/熔断控制

报告位置

- 报告 1: .testagent/scan-report-1/
- 报告 2: .testagent/scan-report-2/

两个工作流均未通过安全门禁，建议优先修复 CRITICAL 和 HIGH 级别的 CONFIRMED 发现。